

**UNIVERSIDAD PRIVADA DE TACNA
FACULTAD DE INGENIERÍA
ESCUELA DE INGENIERÍA DE SISTEMAS**



**“IMPLEMENTACIÓN DE WAZUH: DETECCIÓN DE
ATAQUES Y RESPUESTA ACTIVA AUTOMATIZADA”**

CURSO:

SI-985 SEGURIDAD DE TECNOLOGÍA DE INFORMACIÓN

ESTUDIANTES:

2022074268 - ANAMPA PANCCA, DAVID JORDAN

2020066922 - VARGAS GUTIÉRREZ, ÁNGEL JOSÉ

2022073896 - SALAS JIMENEZ, WALTER EMMANUEL

2022073898 - HUANCA MERMA, GREGORY BRANDON

DOCENTE:

DR. RENZO ALBERTO TACO COAYLA

TACNA — PERÚ

2026

Resumen

Este proyecto presenta a Wazuh, una plataforma gratuita y de código abierto que integra capacidades de gestión de eventos e información de seguridad (SIEM) y de detección y respuesta extendidas (XDR), como alternativa viable para vigilar en tiempo real computadoras y servidores de organizaciones con recursos limitados. El documento sigue una estructura de proyecto basada en las prácticas del Project Management Institute (2021) e incluye el planteamiento del problema, el marco teórico, la revisión de 40 fuentes especializadas, las decisiones técnicas adoptadas, el diseño de un prototipo de laboratorio y el plan de gestión de riesgos. El prototipo consiste en instalar un servidor Wazuh, conectar un agente en un equipo de prueba y demostrar que el sistema detecta un ataque de fuerza bruta contra el servicio SSH y lo bloquea automáticamente mediante respuesta activa. Los resultados se evalúan con indicadores de tiempo de detección, tiempo de contención y cobertura de monitoreo.

Palabras clave: Wazuh, SIEM, XDR, respuesta activa, seguridad de la información, monitoreo continuo

Introducción

Las organizaciones dependen de sistemas informáticos que están expuestos de manera permanente a intentos de intrusión. Según IBM Security, el costo promedio global de una filtración de datos fue de 4,45 millones de dólares, y identificar y contener un incidente tomaba en promedio 277 días. Por su parte, Verizon reporta que las credenciales robadas y los errores humanos figuran entre los vectores más frecuentes de intrusión. Estas cifras muestran que el problema no es solo prevenir ataques, sino detectarlos y contenerlos con rapidez.

Frente a este escenario, los marcos de referencia recomiendan el monitoreo continuo de la seguridad. Sin embargo, no todas las organizaciones disponen de presupuesto para adquirir licencias de plataformas SIEM, por lo que este proyecto evalúa una alternativa sin costo de licencia. Wazuh es una plataforma gratuita y de código abierto que permite recolectar, analizar y correlacionar eventos de seguridad de equipos y servidores, y que además puede ejecutar acciones automáticas de contención.

El presente documento se organiza como sigue: primero se plantea el problema y los objetivos; luego se desarrolla el marco teórico y la revisión de la literatura; después se justifican las decisiones técnicas y se describe el prototipo de laboratorio; finalmente se presenta la gestión del proyecto, las conclusiones y las referencias.

Planteamiento del Problema y Justificación

Problema

En muchas organizaciones los registros (logs) de servidores y estaciones de trabajo permanecen dispersos y sin revisión, de modo que un intento de intrusión pasa inadvertido durante días o semanas. Cuando finalmente se detecta, la respuesta depende de una persona que debe intervenir manualmente. La falta de visibilidad centralizada y de respuesta automática amplía el tiempo de exposición y, con él, el daño potencial (IBM Security, 2023). Este problema es real y no responde solo al interés tecnológico del equipo, por tres razones verificables: (a) está cuantificado en informes independientes de la industria (IBM Security, 2023; Verizon, 2023); (b) los estándares exigen capacidades de registro, monitoreo y detección de cambios, como los requisitos 10 y 11.5 de PCI DSS v4.0 (PCI Security Standards Council, 2022), los controles de auditoría y monitoreo de NIST SP 800-53 (Joint Task Force, 2020) y el Control 8 de CIS (Center for Internet Security, 2021); y (c) la norma ISO/IEC 27001:2022 requiere evaluar el desempeño del sistema de gestión de seguridad, lo que presupone contar con evidencia técnica de monitoreo..

Justificación

Los SIEM permiten centralizar y correlacionar eventos para apoyar la detección y la investigación de incidentes (Bhatt et al., 2014; Miller et al., 2011). Contar con una alternativa libre reduce la barrera económica de acceso a estas capacidades y, además, resulta valiosa académicamente porque permite examinar su funcionamiento interno, a diferencia de una caja negra comercial. Wazuh cuenta con un repositorio público de código fuente (Wazuh, Inc., s. f.-g) y con documentación oficial detallada, lo que facilita su estudio y reproducibilidad.

Beneficios cuantificables esperados

Si la solución se implementará mañana en una organización real, el beneficio se mediría con los indicadores de la Tabla 1. El costo de licenciamiento del software es de cero dólares, y las mejoras operativas se verificarán con datos obtenidos del prototipo. Las metas son propuestas de diseño y se validará o ajustarán con las mediciones de laboratorio.

Tabla 1

Indicadores de beneficio del proyecto

Indicador	Definición	Meta propuesta	Fuente de medición
Costo de licencias	Pago por software de monitoreo	USD 0	Licencia de código abierto
Tiempo de detección (MTTD)	Del primer intento fallido a la alerta en el panel	< 60 s	Marcas de tiempo del Dashboard
Tiempo de contención (MTTR)	De la alerta al bloqueo de la IP atacante	≤ 10 s	Registro de respuesta activa
Cobertura de monitoreo	Equipos con agente activo / equipos totales	100 % del laboratorio	Módulo de agentes
Accesos logrados tras el bloqueo	Intentos exitosos del atacante luego del bloqueo	0	Registros de autenticación

Nota. MTTD = tiempo medio de detección; MTTR = tiempo medio de respuesta. Las metas están por validar con el prototipo.

Objetivos y Alcance

Objetivo general

Implementar y demostrar un sistema Wazuh que monitoree un equipo de prueba, detecte un ataque de fuerza bruta contra SSH y aplique una respuesta activa automática.

Objetivos específicos

1. Describir qué es Wazuh y cómo funciona su arquitectura de servidor central y agentes.
2. Instalar el servidor Wazuh y conectar al menos un agente en un equipo de prueba.
3. Simular un ataque de fuerza bruta y comprobar la detección y el bloqueo automático de la IP atacante.
4. Evaluar el desempeño con los indicadores de la Tabla 1.
5. Sustentar las decisiones técnicas con una revisión de 40 fuentes especializadas.

Alcance y limitaciones

El proyecto se limita a un laboratorio virtual aislado con un servidor, un agente y un equipo atacante. No incluye despliegue en producción, alta disponibilidad ni integración con sistemas externos.

Organización del equipo

El proyecto será desarrollado por 4 integrantes: David Anampa, [nombre del integrante 2] y [nombre del integrante 3] y [nombre del integrante 4]. Para evitar que el trabajo recayera en una sola persona, se repartieron las tareas según las fases del cronograma (Tabla 7): [integrante 1] se encargó de ____; [integrante 2] se encargó de ____; [integrante 3] se encargó de _____. Las decisiones técnicas se tomaron en reuniones de equipo y los cambios de configuración se anotaron en una bitácora compartida (Anexo C).

Marco Teórico

Monitoreo continuo y principios de seguridad

Los principios clásicos de diseño seguro, como la mediación completa y el registro de acciones para su verificación, fueron formulados por Saltzer y Schroeder (1975) y siguen vigentes en los textos modernos de ingeniería de seguridad (Anderson, 2020; Stallings & Brown, 2018). NIST define el monitoreo continuo de la seguridad de la información como el mantenimiento de una visibilidad permanente sobre la postura de seguridad para apoyar decisiones de riesgo (Dempsey et al., 2011), y la gestión de registros como una práctica base para ello (Kent & Souppaya, 2006; Chuvakin et al., 2013).

Detección de intrusiones

El modelo de detección de intrusiones fue propuesto por Denning (1987), y luego se consolidaron dos enfoques: la detección basada en firmas o reglas y la basada en anomalías (Liao et al., 2013; Scarfone & Mell, 2007). También se distinguen los sistemas de red, como Snort (Roesch, 1999) y Bro (Paxson, 1999), y los sistemas de host, que observan lo que

ocurre en cada equipo. Entre estos últimos destaca Tripwire, pionero en la verificación de integridad de archivos (Kim & Spafford, 1994), y OSSEC (Hay et al., 2008), de cuyo código deriva Wazuh. Mitchell y Chen (2014) subrayan que la elección de técnica depende del entorno protegido.

SIEM y XDR

Un SIEM reúne la gestión de información de seguridad y la gestión de eventos: recolecta registros, los normaliza, los correlaciona y genera alertas (Bhatt et al., 2014; Miller et al., 2011). González-Granadillo et al. (2021) analizan su evolución y su uso en infraestructuras críticas, mientras que Cinque et al. (2018) identifican como desafíos el volumen de datos y la calidad de las alertas. Bejtlich (2013) enfatiza que la detección de valor requiere contexto y analistas capaces de interpretar la evidencia. El término XDR alude a la ampliación de estas capacidades hacia la detección y respuesta sobre los puntos finales.

¿Qué es Wazuh?

Wazuh es una plataforma de seguridad gratuita y de código abierto que unifica capacidades de SIEM y XDR para proteger equipos, servidores y entornos en la nube (Wazuh, Inc., s. f.-d). Sus capacidades principales incluyen el análisis de registros, la monitorización de integridad de archivos (Wazuh, Inc., s. f.-c), la detección de vulnerabilidades (Wazuh, Inc., s. f.-f), la evaluación de la configuración de seguridad (Wazuh, Inc., s. f.-e), el soporte a requisitos de cumplimiento normativo y la respuesta activa (Wazuh, Inc., s. f.-a).

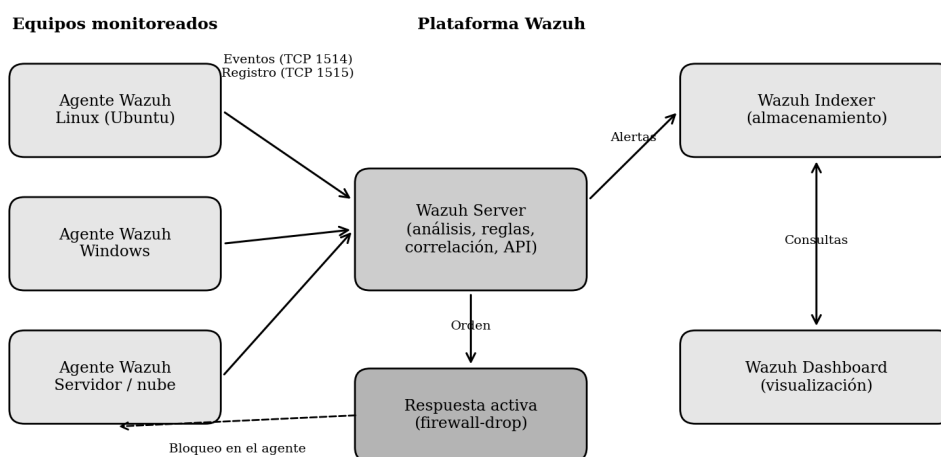
Cómo funciona: servidor central y agentes

Según la documentación oficial, la arquitectura se compone de agentes instalados en los equipos a proteger y de un servidor central que analiza los datos recibidos (Wazuh, Inc., s. f.-b). Los agentes son programas ligeros que recolectan eventos y los envían al servidor. Este los decodifica y los compara con un conjunto de reglas para producir alertas, que se

almacenan en el Wazuh Indexer, basado en OpenSearch (OpenSearch Project, s. f.), y se visualizan en el Wazuh Dashboard. La Figura 1 resume el flujo y la Tabla 2 detalla los componentes.

Figura 1

Arquitectura de Wazuh y flujo de respuesta activa



Nota. Elaboración propia con base en la documentación oficial de Wazuh (Wazuh, Inc., s. f.-b).

Tabla 2

Componentes de la plataforma Wazuh

Componente	Función	Puerto habitual
Agente	Recolecta eventos, verifica integridad de archivos y ejecuta las órdenes de respuesta activa	Se conecta al servidor
Servidor (manager)	Decodifica eventos, aplica reglas, genera alertas y expone la API	1514 (eventos), 1515 (registro), 55000 (API)
Indexer	Almacena e indexa las alertas	9200
Dashboard	Interfaz web de visualización y administración	443

Nota. Puertos según la configuración predeterminada de la documentación oficial; verificar en la versión instalada.

Respuesta activa

La respuesta activa permite que el servidor ordene a un agente ejecutar un script cuando se dispara una regla determinada, por ejemplo, bloquear una dirección IP con el

firewall del sistema durante un tiempo limitado (Wazuh, Inc., s. f.-a). Esto acorta la fase de contención descrita en el ciclo de manejo de incidentes de NIST (Cichonski et al., 2012).

Correlación con MITRE ATT&CK

MITRE ATT&CK es una base de conocimiento de tácticas y técnicas de adversarios (MITRE Corporation, s. f.; Strom et al., 2018). Las reglas de Wazuh incluyen referencias a esta matriz, lo que facilita ubicar cada alerta dentro de la cadena de ataque (Hutchins et al., 2011). El ataque de fuerza bruta de este proyecto corresponde a la técnica T1110 (Brute Force) de la táctica de acceso a credenciales.

Análisis de eventos: decodificadores, reglas y severidad

Cuando el agente envía un evento al servidor, este lo procesa en dos pasos. Primero un decodificador extrae los campos útiles del registro (por ejemplo, el usuario y la dirección IP de origen de un intento de acceso por SSH). Luego el motor de reglas compara esos campos con las reglas cargadas y, si alguna coincide, genera una alerta con un nivel de severidad y una descripción (Wazuh, Inc., s. f.-b). Este mecanismo explica por qué un solo intento fallido de acceso no dispara el bloqueo, mientras que varios intentos seguidos en poco tiempo sí activan la regla de fuerza bruta. Por esa razón, en el prototipo el ataque se lanza con una lista de contraseñas y no con un intento aislado, y el bloqueo se configura sobre la regla de fuerza bruta y no sobre un fallo individual.

Revisión de la Literatura

Fuentes consultadas

Se revisaron 40 fuentes especializadas, agrupadas en la Tabla 3. Se priorizaron la documentación oficial de Wazuh, las normas y guías de NIST, los estudios académicos sobre detección de intrusiones y SIEM, y los informes de la industria sobre costos e incidentes.

Tabla 3*Tipología de las 40 fuentes revisadas*

Tipo de fuente	n	Ejemplos
Libros	7	Anderson (2020); Bejtlich (2013); Miller et al. (2011); Stallings y Brown (2018)
Artículos académicos y de congresos	12	Denning (1987); Liao et al. (2013); Sommer y Paxson (2010); González-Granadillo et al. (2021)
Informes técnicos y de industria	3	IBM Security (2023); Verizon (2023); Strom et al. (2018)
Normas y marcos de referencia	9	NIST SP 800-53, 800-61, 800-137; CIS Controls; ISO/IEC 27001; PCI DSS
Documentación oficial y sitios técnicos	9	Wazuh (7 documentos); MITRE ATT&CK; OpenSearch

Nota. Elaboración propia.

Tres hallazgos principales y su efecto en el diseño

Hallazgo 1. Detectar sin responder no basta. Los informes de la industria muestran que el tiempo de permanencia del atacante determina el costo del incidente (IBM Security, 2023), y el ciclo de NIST sitúa la contención como fase crítica (Cichonski et al., 2012). *Efecto en el diseño:* además de la detección, el prototipo incorpora una respuesta activa automática y mide el tiempo hasta el bloqueo.

Hallazgo 2. Las reglas por sí solas tienen límites. Sommer y Paxson (2010) advierten que los métodos de detección deben adaptarse al contexto operativo, y Liao et al. (2013) señalan que las técnicas basadas en firmas no detectan ataques desconocidos. *Efecto en el diseño:* se eligió un escenario conocido y medible (fuerza bruta), se utilizan reglas contextualizadas con MITRE ATT&CK y se declaran los falsos positivos como riesgo con lista blanca de IP administrativas.

Hallazgo 3. Los estándares exigen capacidades que Wazuh cubre. PCI DSS, NIST SP 800-53, CIS Controls e ISO/IEC 27001 exigen registro, monitoreo, control de integridad y evaluación de configuración (Center for Internet Security, 2021; International Organization for Standardization & International Electrotechnical Commission, 2022; Joint Task Force,

2020; PCI Security Standards Council, 2022). *Efecto en el diseño*: además de la respuesta activa, el proyecto incluye pruebas secundarias de integridad de archivos y de evaluación de configuración para mostrar la utilidad de la plataforma más allá del caso demostrativo.

Decisiones Técnicas y Alternativas Evaluadas

La Tabla 4 resume las decisiones tomadas, las alternativas consideradas y la justificación. La comparación entre productos es cualitativa y se basa en las características generales de cada uno y en la literatura revisada.

Tabla 4

Decisiones técnicas, alternativas y justificación

Decisión	Alternativas evaluadas	Justificación
Plataforma de monitoreo	Splunk, Elastic Security, Graylog, Security Onion, OSSEC	Wazuh es gratuito, integra SIEM y XDR, incluye respuesta activa lista para usar y deriva de OSSEC (Hay et al., 2008), con documentación oficial completa.
Tipo de despliegue	Distribuido (componentes separados) frente a todo en uno	El modo todo en uno mediante el asistente de instalación (Wazuh, Inc., s. f.-d) es suficiente para un laboratorio y reduce la complejidad.
Sistema operativo del servidor	Ubuntu Server 22.04 LTS u otras distribuciones	Distribución compatible con Wazuh, de soporte prolongado y familiar para el equipo.
Escenario de ataque	Escaneo de puertos, malware, fuerza bruta SSH	La fuerza bruta contra SSH es reproducible, segura en laboratorio, corresponde a MITRE T1110 y activa reglas ya incluidas.
Respuesta activa	Solo alertar; bloquear con firewall; deshabilitar la cuenta	El bloqueo temporal con firewall-drop es reversible y limita el impacto de un falso positivo.
Red del laboratorio	Red puente, NAT, red solo anfitrión	La red solo anfitrión aísla el ataque y evita afectar equipos ajenos.

Nota. Elaboración propia.

Prototipo: Diseño y Demostración Práctica

Entorno de laboratorio

Tabla 5

Máquinas virtuales del laboratorio

Máquina	Rol	Sistema operativo	Recursos sugeridos
wazuh-server	Servidor Wazuh todo en uno	Ubuntu Server 22.04	4 vCPU, 8 GB RAM, 50 GB

Máquina	Rol	Sistema operativo	Recursos sugeridos
victima-linux	Equipo protegido con agente	Ubuntu Server 22.04 con SSH	1–2 vCPU, 2 GB RAM
atacante	Origen del ataque	Kali Linux	2 vCPU, 2 GB RAM

Nota. Red solo anfitrión (p. ej., 192.168.56.0/24). Los requisitos de la instalación rápida están en la documentación oficial (Wazuh, Inc., s. f.-d).

Procedimiento

1. Instalar el servidor Wazuh con el asistente oficial (Anexo A, comando 1) y guardar las credenciales que entrega al finalizar.
2. Ingresar al Dashboard por HTTPS y generar el comando de despliegue de agente desde la sección de agentes.
3. Ejecutar ese comando en victima-linux y verificar que el agente aparezca como activo.
4. Configurar la respuesta activa en el servidor (Anexo A, comando 3) y reiniciar el servicio.
5. Lanzar el ataque de fuerza bruta desde la máquina atacante (Anexo A, comando 4).
6. Verificar en el Dashboard la alerta de fuerza bruta y el bloqueo, y comprobar la regla del firewall en el agente.
7. Registrar los tiempos y esperar el desbloqueo automático; documentar cada paso con capturas.

La regla 5763 de Wazuh describe múltiples fallos de autenticación en sshd y es la que se asocia a la respuesta activa en este prototipo. El identificador de la regla y sus umbrales se verifican en el conjunto de reglas de la versión instalada. Como pruebas complementarias, se modificará un archivo bajo vigilancia para observar la alerta de integridad (Wazuh, Inc., s. f.-c) y se revisarán los resultados de la evaluación de configuración (Wazuh, Inc., s. f.-e) y de vulnerabilidades (Wazuh, Inc., s. f.-f).

Evidencia del prototipo

La evidencia del prototipo se presenta en las Figuras 2 a 4 y en la Tabla 6, con las capturas y las mediciones obtenidas al ejecutar el procedimiento descrito en el laboratorio virtual.

Figura 2

Agente conectado y activo en el Wazuh Dashboard

Figura 3

Alerta de fuerza bruta SSH en el módulo de eventos

Figura 4

Evidencia del bloqueo automático de la IP atacante

Tabla 6

Resultados de la medición del prototipo

Indicador	Meta	Resultado obtenido	¿Cumple?
Tiempo de detección (s)	< 60	[completar]	[]
Tiempo de contención (s)	≤ 10	[completar]	[]
Cobertura de agentes (%)	100	[completar]	[]
Accesos logrados tras el bloqueo	0	[completar]	[]

Nota. Mediciones del laboratorio virtual de la Tabla 5; cada tiempo se calcula con las marcas de tiempo del Dashboard y del registro de respuesta activa.

Análisis de resultados

Una vez completada la Tabla 6, esta sección compara cada resultado con su meta y explica las diferencias.

Dificultades encontradas y soluciones

.....

Limitaciones del prototipo:

El prototipo usa un solo agente, un solo tipo de ataque y una red aislada, por lo que sus resultados no pueden generalizarse a una organización con cientos de equipos, tráfico real y usuarios legítimos que se equivocan al escribir su contraseña. Tampoco se evaluó el consumo de recursos del servidor bajo carga ni la tasa de falsos positivos con tráfico normal; ambos aspectos quedan como trabajo futuro.

Gestión del Proyecto (Enfoque PMI):

Acta de constitución resumida

El proyecto tiene como patrocinador al docente del curso y como equipo ejecutor a los estudiantes integrantes. Su propósito es demostrar la viabilidad técnica de Wazuh como herramienta de monitoreo y respuesta. Los criterios de éxito son el cumplimiento de los objetivos específicos, la evidencia funcional del prototipo y la entrega del informe, la presentación y el repositorio público. Se sigue el enfoque de entrega de valor y gestión de riesgos propuesto en la guía del PMBOK (Project Management Institute, 2021).

Estructura de desglose y cronograma:

Tabla 7

Fases, entregables y cronograma

Fase	Entregable	Semana
Inicio	Acta de constitución, alcance y roles	1
Planificación	Revisión de 40 fuentes y diseño del laboratorio	1–2
Ejecución I	Servidor instalado y agente conectado	3
Ejecución II	Ataque simulado y respuesta activa	4
Monitoreo y control	Mediciones y evidencias	5
Cierre	Informe Word/PDF, presentación, repositorio GitHub y sustentación	6

Nota. Cronograma referencial, ajustable al calendario del curso.

Costos

El desembolso directo es nulo porque todo el software es libre (Wazuh, Ubuntu, Kali Linux y un hipervisor gratuito) y se emplean equipos que ya posee el autor. El único costo es el tiempo que el autor dedica al proyecto.

Riesgos y estrategias de mitigación

La Tabla 8 identifica los riesgos técnicos, operativos y de gestión que podrían comprometer la continuidad del proyecto, con su estrategia de mitigación.

Tabla 8

Registro de riesgos

ID	Riesgo	Tipo	P/I	Mitigación
R1	Recursos de hardware insuficientes para el servidor	Técnico	M/A	Asignar 4 vCPU y 8 GB de RAM; usar instantáneas; cerrar otras aplicaciones
R2	Incompatibilidad de versiones entre agente y servidor	Técnico	M/M	Instalar desde el mismo repositorio y verificar versiones
R3	Falso positivo que bloquee una IP legítima	Operativo	M/M	Lista blanca de IP administrativas y tiempo de bloqueo acotado (180 s)
R4	Bloqueo de la propia IP de administración	Operativo	B/A	Registrar la IP del administrador en la lista blanca antes de las pruebas
R5	Retrasos por disponibilidad del equipo	Gestión	M/M	Roles definidos, reunión semanal y holgura de una semana
R6	Pérdida de configuraciones o evidencias	Gestión	B/A	Instantáneas de las VM y respaldo en GitHub y Drive/OneDrive
R7	Uso indebido de herramientas ofensivas	Ético-legal	B/A	Red aislada, autorización del docente y ataques solo a equipos propios
R8	Obsolescencia de la configuración con nuevas versiones	Continuidad	M/B	Seguir las notas de versión y documentar los pasos en el repositorio

Nota. P/I = probabilidad/impacto (B = bajo, M = medio, A = alto). Elaboración propia.

Conclusiones y Recomendaciones:

Wazuh reúne en una sola plataforma gratuita las funciones de recolección, análisis, alerta y respuesta que la literatura y los estándares consideran esenciales para el monitoreo continuo. Su arquitectura de agentes y servidor permite un despliegue sencillo en un laboratorio y escalable a entornos mayores. El prototipo diseñado permite demostrar el ciclo completo de detección y contención automática de un ataque de fuerza bruta y medir el beneficio con indicadores objetivos.

Se recomienda ampliar el proyecto con la integración de más agentes, la revisión de vulnerabilidades y la evaluación de configuración, así como la elaboración de reglas propias y la integración con canales de notificación.

Referencias

- Anderson, R. (2020). *Security engineering: A guide to building dependable distributed systems* (3.^a ed.). Wiley.
- Bejtlich, R. (2013). *The practice of network security monitoring: Understanding incident detection and response*. No Starch Press.
- Bhatt, S., Manadhata, P. K., & Zomlot, L. (2014). The operational role of security information and event management systems. *IEEE Security & Privacy*, 12(5), 35–41.
<https://doi.org/10.1109/MSP.2014.103>
- Center for Internet Security. (2021). *CIS Controls* (Versión 8).
<https://www.cisecurity.org/controls>
- Chuvakin, A., Schmidt, K., & Phillips, C. (2013). *Logging and log management: The authoritative guide to understanding the concepts surrounding logging and log management*. Syngress.
- Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer security incident handling guide* (NIST Special Publication 800-61, Rev. 2). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>
- Cinque, M., Cotroneo, D., & Pecchia, A. (2018). Challenges and directions in security information and event management (SIEM). En *2018 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW)* (pp. 95–99). IEEE.
- Dempsey, K., Chawla, N. S., Johnson, A., Johnston, R., Jones, A. C., Orebaugh, A. D., Scholl, M., & Stine, K. (2011). *Information security continuous monitoring (ISCM) for federal information systems and organizations* (NIST Special Publication 800-137). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-137>

- Denning, D. E. (1987). An intrusion-detection model. *IEEE Transactions on Software Engineering*, SE-13(2), 222–232. <https://doi.org/10.1109/TSE.1987.232894>
- González-Granadillo, G., González-Zarzosa, S., & Diaz, R. (2021). Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures. *Sensors*, 21(14), Artículo 4759. <https://doi.org/10.3390/s21144759>
- Hay, A., Cid, D., & Bray, R. (2008). *OSSEC host-based intrusion detection guide*. Syngress.
- Hutchins, E. M., Cloppert, M. J., & Amin, R. M. (2011). Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 1(1), 80–106.
- IBM Security. (2023). *Cost of a data breach report 2023*. IBM. <https://www.ibm.com/reports/data-breach>
- International Organization for Standardization & International Electrotechnical Commission. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements (ISO/IEC 27001:2022)*.
- Joint Task Force. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-53r5>
- Kent, K., & Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-92>
- Kim, G. H., & Spafford, E. H. (1994). The design and implementation of Tripwire: A file system integrity checker. En *Proceedings of the 2nd ACM Conference on Computer and Communications Security* (pp. 18–29). ACM. <https://doi.org/10.1145/191177.191183>

- Liao, H.-J., Lin, C.-H. R., Lin, Y.-C., & Tung, K.-Y. (2013). Intrusion detection system: A comprehensive review. *Journal of Network and Computer Applications*, 36(1), 16–24. <https://doi.org/10.1016/j.jnca.2012.09.004>
- Miller, D. R., Harris, S., Harper, A. A., VanDyke, S., & Blask, C. (2011). *Security information and event management (SIEM) implementation*. McGraw-Hill.
- Mitchell, R., & Chen, I.-R. (2014). A survey of intrusion detection techniques for cyber-physical systems. *ACM Computing Surveys*, 46(4), Artículo 55. <https://doi.org/10.1145/2542049>
- MITRE Corporation. (s. f.). *MITRE ATT&CK®*. <https://attack.mitre.org/>
- National Institute of Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity* (Versión 1.1). <https://doi.org/10.6028/NIST.CSWP.04162018>
- OpenSearch Project. (s. f.). *OpenSearch documentation*. <https://opensearch.org/docs/latest/>
- Paxson, V. (1999). Bro: A system for detecting network intruders in real-time. *Computer Networks*, 31(23–24), 2435–2463. [https://doi.org/10.1016/S1389-1286\(99\)00112-7](https://doi.org/10.1016/S1389-1286(99)00112-7)
- PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard: Requirements and testing procedures* (Versión 4.0).
- Project Management Institute. (2021). *A guide to the project management body of knowledge (PMBOK® guide)* (7.^a ed.).
- Roesch, M. (1999). Snort: Lightweight intrusion detection for networks. En *Proceedings of the 13th USENIX Conference on System Administration (LISA '99)* (pp. 229–238). USENIX Association.
- Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE*, 63(9), 1278–1308. <https://doi.org/10.1109/PROC.1975.9939>

- Scarfone, K., & Mell, P. (2007). *Guide to intrusion detection and prevention systems (IDPS)* (NIST Special Publication 800-94). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-94>
- Sommer, R., & Paxson, V. (2010). Outside the closed world: On using machine learning for network intrusion detection. En *2010 IEEE Symposium on Security and Privacy* (pp. 305–316). IEEE. <https://doi.org/10.1109/SP.2010.25>
- Stallings, W., & Brown, L. (2018). *Computer security: Principles and practice* (4.^a ed.). Pearson.
- Strom, B. E., Applebaum, A., Miller, D. P., Nickels, K. C., Pennington, A. G., & Thomas, C. B. (2018). *MITRE ATT&CK®: Design and philosophy* (Technical Report MP180360R1). The MITRE Corporation.
- Verizon. (2023). *2023 data breach investigations report*.
<https://www.verizon.com/business/resources/reports/dbir/>
- Wazuh, Inc. (s. f.-a). *Active response*. Wazuh documentation.
<https://documentation.wazuh.com/current/user-manual/capabilities/active-response/index.html>
- Wazuh, Inc. (s. f.-b). *Architecture*. Wazuh documentation.
<https://documentation.wazuh.com/current/getting-started/architecture.html>
- Wazuh, Inc. (s. f.-c). *File integrity monitoring*. Wazuh documentation.
<https://documentation.wazuh.com/current/user-manual/capabilities/file-integrity/index.html>
- Wazuh, Inc. (s. f.-d). *Quickstart*. Wazuh documentation.
<https://documentation.wazuh.com/current/quickstart.html>

Wazuh, Inc. (s. f.-e). *Security configuration assessment*. Wazuh documentation.

<https://documentation.wazuh.com/current/user-manual/capabilities/sec-config-assessment/index.html>

Wazuh, Inc. (s. f.-f). *Vulnerability detection*. Wazuh documentation.

<https://documentation.wazuh.com/current/user-manual/capabilities/vulnerability-detection/index.html>

Wazuh, Inc. (s. f.-g). *Wazuh* [Repositorio de código fuente]. GitHub.

<https://github.com/wazuh/wazuh>

Anexo A

Comandos del prototipo

Los comandos deben adaptarse a la versión vigente indicada en la guía de instalación rápida (Wazuh, Inc., s. f.-d). Las direcciones IP son ejemplos.

1. Instalación del servidor (todo en uno). Sustituir <VERSIÓN> por la que indique la documentación oficial (p. ej., 4.14):

```
curl -sO https://packages.wazuh.com/<VERSIÓN>/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
```

2. Despliegue del agente. Copiar el comando que genera el Dashboard, que tiene esta forma (ejemplo):

```
WAZUH_MANAGER='192.168.56.10' apt-get install wazuh-agent
sudo systemctl enable --now wazuh-agent
```

3. Respuesta activa en el servidor. Agregar en /var/ossec/etc/ossec.conf y reiniciar con sudo systemctl restart wazuh-manager:

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5763</rules_id>
  <timeout>180</timeout>
</active-response>
```

4. Ataque de laboratorio desde la máquina atacante, contra la IP de la víctima y un usuario de prueba:

```
hydra -l usuario_prueba -P lista_contrasenas.txt ssh://192.168.56.20 -t 4
```

5. Verificación en el agente:

```
sudo tail -f /var/ossec/logs/active-responses.log
sudo iptables -L -n
```

Anexo B

Respuestas a las preguntas de sustentación

Pregunta 1. ¿Cuál es el problema real que busca resolver su proyecto y cómo demuestra que existe más allá del interés tecnológico del equipo?

El problema real es que muchas organizaciones detectan tarde las intrusiones y las contienen de forma manual, porque sus registros están dispersos y nadie los correlaciona. No depende del interés tecnológico del equipo, ya que se sustenta en tres evidencias independientes: (a) IBM Security (2023) estimó en 4,45 millones de dólares el costo promedio de una filtración de datos y en 277 días el tiempo promedio para identificarla y contenerla; (b) Verizon (2023) muestra que las credenciales robadas y los errores humanos figuran entre los vectores de intrusión más frecuentes, lo que respalda la elección de la fuerza bruta como escenario; y (c) PCI DSS v4.0 (requisitos 10 y 11.5), NIST SP 800-53 y el Control 8 de CIS exigen registro, monitoreo y detección de cambios (Center for Internet Security, 2021; Joint Task Force, 2020; PCI Security Standards Council, 2022). Como análisis crítico, estas cifras son promedios globales y no describen a una institución en particular; por ello el proyecto no afirma que Wazuh elimine ese costo, sino que verifica en un entorno controlado si reduce el tiempo de detección y de contención.

Pregunta 2. Si su solución tuviera que implementarse mañana en una organización real, ¿qué beneficio cuantificable obtendría el usuario o la institución?

El beneficio se expresa con cinco indicadores (Tabla 1): costo de licencias de USD 0; tiempo de detección menor de 60 s; tiempo de contención de 10 s o menos; cobertura de monitoreo del 100 % de los equipos; y ningún acceso logrado después del bloqueo. Los valores reales se registran en la Tabla 6 a partir de las marcas de tiempo del Dashboard y del registro de respuesta activa. Para dimensionar el efecto, IBM Security (2023) reporta 277 días de identificación y contención en promedio, frente a los segundos que se medirían en el

prototipo para un ataque conocido. Esta comparación es solo orientativa: el laboratorio mide un único tipo de ataque en un entorno controlado, y el ahorro económico real de una institución dependería también del costo de operación (horas de administración, hardware y capacitación), que solo un piloto en producción puede medir.

Pregunta 3. ¿Qué decisiones técnicas tomaron durante el proyecto, qué alternativas evaluaron y por qué descartaron las demás opciones?

Las decisiones se resumen en la Tabla 4. Se eligió Wazuh frente a Splunk, Elastic Security, Graylog, Security Onion y OSSEC porque no tiene costo de licencia, integra funciones de SIEM y XDR, incluye respuesta activa y deriva de OSSEC (Hay et al., 2008), además de contar con documentación oficial completa. Se optó por el despliegue todo en uno porque es suficiente para un laboratorio y reduce la complejidad; por Ubuntu Server 22.04 LTS por su compatibilidad y soporte prolongado; por la fuerza bruta contra SSH (técnica T1110 de MITRE ATT&CK) porque es reproducible, segura en laboratorio y activa reglas ya incluidas; por el bloqueo temporal con firewall-drop porque es reversible y limita el impacto de un falso positivo; y por una red solo anfitrión para aislar el ataque. Como limitación, la comparación entre plataformas es cualitativa: no se realizaron pruebas comparativas con las demás herramientas, de modo que la elección responde a criterios de costo, integración y reproducibilidad, y no a un desempeño superior demostrado. Si el proyecto escalara, correspondería reevaluar un despliegue distribuido.

Pregunta 4. ¿Cómo la revisión de los 40 artículos o libros influyó en el diseño de la solución y cuáles fueron los tres hallazgos más importantes encontrados en la literatura?

La revisión de las 40 fuentes (Tabla 3) dejó tres hallazgos que modificaron el diseño. Primero, detectar sin responder no basta: el tiempo de permanencia del atacante determina el costo del incidente (IBM Security, 2023) y la contención es una fase crítica del ciclo de NIST (Cichonski et al., 2012), por lo que el prototipo incluye respuesta activa y mide el tiempo

hasta el bloqueo. Segundo, las reglas por sí solas tienen límites: la detección debe adaptarse al contexto (Sommer & Paxson, 2010) y las técnicas basadas en firmas no detectan ataques desconocidos (Liao et al., 2013), por lo que se eligió un escenario conocido y medible y se declararon los falsos positivos como riesgo, con una lista blanca de IP. Tercero, los estándares exigen capacidades de registro, monitoreo, integridad y configuración que Wazuh cubre (Joint Task Force, 2020; PCI Security Standards Council, 2022), por lo que se añadieron pruebas secundarias de integridad de archivos y de evaluación de configuración. Como análisis crítico, 9 de las 40 fuentes son documentación técnica y 3 son informes de la industria, que no pasan por arbitraje académico; los fundamentos conceptuales descansan en 12 artículos y 7 libros.

Pregunta 5. ¿Qué riesgos técnicos, operativos o de gestión identifica para la continuidad del proyecto y qué estrategia propone para mitigarlos?

Los riesgos se registran en la Tabla 8. Los de mayor impacto son: hardware insuficiente para el servidor (R1), que se mitiga asignando 4 vCPU y 8 GB de RAM y usando instantáneas; el falso positivo que bloquee una IP legítima (R3) y el bloqueo de la propia IP de administración (R4), que se mitigan con una lista blanca y un bloqueo temporal de 180 s; la pérdida de configuraciones o evidencias (R6), con instantáneas de las máquinas virtuales y respaldo en GitHub y en la nube; y el uso indebido de herramientas ofensivas (R7), con una red aislada, autorización del docente y ataques solo contra equipos propios. Para la continuidad se documentan los pasos en el repositorio y se siguen las notas de versión de Wazuh (R8). Como riesgo residual, la automatización no reemplaza al analista: Bejtlich (2013) subraya que la detección de valor requiere contexto y personas capaces de interpretar la evidencia, por lo que toda respuesta activa en producción debería probarse y ajustarse antes de habilitarse.

Anexo C

Enlace del proyecto y estructura del repositorio

https://github.com/David-Anampa/PG_SEGURIDAD_TI_WAZUH_ANAMPA_HUA

[NCA_SALAS_VARGAS.git](#)

```
proyecto-wazuh/  
├── index.html  
├── README.md  
├── docs/  
│   ├── Informe_Wazuh_APA.docx  
│   ├── Informe_Wazuh_APA.pdf  
│   └── Presentacion_Wazuh.pptx  
├── config/ossec-active-response.xml  
├── evidencias/ (capturas y registros)  
└── referencias/bibliografia_APA7.md
```